

SX

SentinelX External Exposure Intelligence Report

Passive Reconnaissance Assessment — Confidential

cal.com

Generated: 2026-03-04 16:46 UTC

 ASSESSMENT METADATA

ASSESSMENT TYPE	External Passive Reconnaissance
TARGET SCOPE	External passive reconnaissance of cal.com and its publicly observable subdomain infrastructure
TIMESTAMP	2026-03-04T16:46:38.511599+00:00
SCANNER VERSION	SentinelX v1.2.0
ANALYST	Karhtikeya velivela
METHODOLOGY	Passive external reconnaissance only. All data collected from publicly accessible sources including: HTTPS certificate inspection, HTTP response header analysis, DNS record enumeration, certificate transparency log queries (crt.sh), favicon hash fingerprinting, and TCP port probing of well-known service ports. No authentication, exploitation, or active intrusive testing was performed at any stage.



Medium Exposure

Moderate external exposure. Several risk indicators were identified. Structured remediation within 60 days is recommended.

5 / 10

EXPOSURE SCORE METHODOLOGY

The Exposure Score is a 1–10 composite metric representing the organisation's external attack surface as observed from a fully passive reconnaissance perspective. Higher scores indicate broader, more exploitable exposure.

- +2

Expired TLS Certificate

An expired certificate disables transport security warnings and signals operational neglect.
- +2

High-Risk Pattern Subdomains Detected

Subdomains matching patterns such as 'dev', 'admin', 'staging' indicate pre-production or privileged surfaces.
- +2

Sensitive Ports Publicly Reachable

Ports such as 22 (SSH), 3306 (MySQL), 3389 (RDP) present direct attack vectors for credential attacks.
- +1

Missing HSTS Header

Absence of Strict-Transport-Security enables protocol downgrade and session interception.
- +1

Missing Content-Security-Policy

Absence of CSP leaves the application unprotected against cross-site scripting injection.
- +1

Missing X-Frame-Options

Without frame protection, authenticated interfaces are vulnerable to clickjacking.

+1

Large Subdomain Attack Surface (>5 hosts)

A broad subdomain footprint increases enumeration potential and the probability of a misconfigured host.

Low (1-3)

Minimal observable exposure. Basic hygiene controls appear to be in place.

Medium (4-7)

Moderate exposure. Several risk indicators present; structured remediation recommended within 60 days.

High (8-10)

Significant external exposure. Immediate prioritised remediation required.

ATTACK SURFACE OVERVIEW

1

Subdomains Discovered

1

Sensitive Open Ports

2

Critical Headers Missing

0

High-Risk Subdomains

✓ Valid

TLS Certificate Status

5

Technology Indicators

Cloudflare

Ember.js

Generator: framer dc36ba6

React

Server: cloudflare

High	1	1
Medium	2	2
Low	2	2

EXECUTIVE SUMMARY**HIGH RISK**

Passive external reconnaissance of cal.com identified a medium exposure posture across 1 resolvable subdomain(s). The assessment surfaced 1 high-severity and 2 medium-severity indicators warranting structured remediation attention.

PRIMARY RISK #1

Sensitive service ports publicly reachable (21) — direct attack surface for credential brute-force, vulnerability exploitation, and lateral movement.

PRIMARY RISK #2

Content-Security-Policy header absent — application is unprotected against cross-site scripting (XSS) and content-injection attacks.



Prioritise remediation of High-severity findings within the next 30 days. Schedule a follow-up passive assessment in 90 days to validate posture improvement.

This assessment relied exclusively on passive, publicly observable signals. No intrusive testing, exploitation, or active probing was performed at any stage.

SECURITY FINDINGS

1. Sensitive service ports publicly reachable (21) — direct attack surface for credential brute-force, vulnerability exploi

A05:2021 – Security Misconfiguration

HIGH

TECHNICAL DESCRIPTION

Sensitive service ports publicly reachable (21) — direct attack surface for credential brute-force, vulnerability exploitation, and lateral movement.

SECURITY IMPACT

This condition represents a validated passive indicator of external exposure. The specific impact depends on how an adversary leverages this signal.

BUSINESS IMPACT

DataExposure Risk	Dependent on service exposed — evaluate data access scope.
Credential Compromise Risk	Possible if authentication interfaces or credentials are reachable.
Infrastructure Enumeration Risk	External adversaries can map service topology from observable signals.
Compliance Risk	May constitute a control gap under SOC 2, PCI-DSS, or GDPR depending on data classification.
Reputation Risk	Publicly observable misconfigurations erode technical credibility with enterprise buyers.

 Threat Scenario

An adversary performing targeted reconnaissance identifies this condition and incorporates it into a structured attack plan, using it as an initial foothold for credential theft, data exfiltration, or further lateral movement.

 Remediation Recommendation

Review this finding with your infrastructure team and apply targeted hardening controls.

 Technology-Specific Implementation

Apply remediation according to your web server and framework documentation.

2. Content-Security-Policy header absent — application is unprotected against cross-site scripting (XSS) and content-inject

A05:2021 – Security Misconfiguration

MEDIUM

TECHNICAL DESCRIPTION

Content-Security-Policy header absent — application is unprotected against cross-site scripting (XSS) and content-injection attacks.

SECURITY IMPACT

This condition represents a validated passive indicator of external exposure. The specific impact depends on how an adversary leverages this signal.

BUSINESS IMPACT

- DataExposure Risk

Dependent on service exposed — evaluate data access scope.
- Credential Compromise Risk

Possible if authentication interfaces or credentials are reachable.
- Infrastructure Enumeration Risk

External adversaries can map service topology from observable signals.
- Compliance Risk

May constitute a control gap under SOC 2, PCI-DSS, or GDPR depending on data classification.
- Reputation Risk

Publicly observable misconfigurations erode technical credibility with enterprise buyers.

 Threat Scenario

An attacker identifies a stored or reflected XSS vulnerability in a user-generated content field. Without a Content-Security-Policy, the injected <script> tag executes freely in the victim's browser. The script silently exfiltrates the session token via an attacker-controlled endpoint, granting authenticated access without any user interaction.

 Remediation Recommendation

Define and deploy a Content-Security-Policy header restricting trusted script, style, and media origins. Start in report-only mode using Content-Security-Policy-Report-Only with a report-uri endpoint to capture violations before enforcing.

 Technology-Specific Implementation

Apply remediation according to your web server and framework documentation.

3. X-Frame-Options header absent — application may be embeddable in third-party frames, enabling clickjacking attacks again

A05:2021 – Security Misconfiguration

MEDIUM

TECHNICAL DESCRIPTION

X-Frame-Options header absent — application may be embeddable in third-party frames, enabling clickjacking attacks against authenticated users.

SECURITY IMPACT

This condition represents a validated passive indicator of external exposure. The specific impact depends on how an adversary leverages this signal.

BUSINESS IMPACT

DataExposure Risk	Dependent on service exposed — evaluate data access scope.
Credential Compromise Risk	Possible if authentication interfaces or credentials are reachable.
Infrastructure Enumeration Risk	External adversaries can map service topology from observable signals.
Compliance Risk	May constitute a control gap under SOC 2, PCI-DSS, or GDPR depending on data classification.
Reputation Risk	Publicly observable misconfigurations erode technical credibility with enterprise buyers.

Threat Scenario

The attacker creates a phishing page that embeds the target application's authenticated payment or account page inside a transparent iFrame. An overlay UI is rendered on top, tricking the authenticated user into clicking a button that triggers a funds transfer or account modification action on the embedded page — with no visible indication of deception.

Remediation Recommendation

Add 'X-Frame-Options: DENY' to all HTTP responses, or use the Content-Security-Policy frame-ancestors directive: frame-ancestors 'none'. Validate using: `curl -I https://{domain} | grep -i frame`

Technology-Specific Implementation

Apply remediation according to your web server and framework documentation.

4. Valid TLS endpoint reachable. Certificate chain and expiry details collected.

A02:2021– Cryptographic Failures

LOW

TECHNICAL DESCRIPTION

Valid TLS endpoint reachable. Certificate chain and expiry details collected.

SECURITY IMPACT

This condition represents a validated passive indicator of external exposure. The specific impact depends on how an adversary leverages this signal.

BUSINESS IMPACT

DataExposure Risk	Dependent on service exposed — evaluate data access scope.
Credential Compromise Risk	Possible if authentication interfaces or credentials are reachable.
Infrastructure Enumeration Risk	External adversaries can map service topology from observable signals.
Compliance Risk	May constitute a control gap under SOC 2, PCI-DSS, or GDPR depending on data classification.
Reputation Risk	Publicly observable misconfigurations erode technical credibility with enterprise buyers.

 Threat Scenario

An adversary performing targeted reconnaissance identifies this condition and incorporates it into a structured attack plan, using it as an initial foothold for credential theft, data exfiltration, or further lateral movement.

 Remediation Recommendation

Review this finding with your infrastructure team and apply targeted hardening controls.

 Technology-Specific Implementation

Apply remediation according to your web server and framework documentation.

5. Technology stack fingerprinted (5 indicators). Public exposure of framework and version information may inform targeted

A06:2021 – Vulnerable and Outdated Components

LOW

TECHNICAL DESCRIPTION

Technology stack fingerprinted (5 indicators). Public exposure of framework and version information may inform targeted research.

SECURITY IMPACT

This condition represents a validated passive indicator of external exposure. The specific impact depends on how an adversary leverages this signal.

BUSINESS IMPACT

DataExposure Risk	Dependent on service exposed — evaluate data access scope.
Credential Compromise Risk	Possible if authentication interfaces or credentials are reachable.
Infrastructure Enumeration Risk	External adversaries can map service topology from observable signals.
Compliance Risk	May constitute a control gap under SOC 2, PCI-DSS, or GDPR depending on data classification.
Reputation Risk	Publicly observable misconfigurations erode technical credibility with enterprise buyers.

Threat Scenario

The detected framework version is cross-referenced with CVE databases, revealing a known Remote Code Execution vulnerability. The attacker downloads a public proof-of-concept and validates it against the target without triggering any security alerts. A reverse shell is established, granting operating system level access to the application server and all data it can reach.

Remediation Recommendation

Suppress version-revealing response headers (Server, X-Powered-By, X-Generator). In Nginx: `server_tokens off`; In Apache: `ServerTokens Prod`; `ServerSignature Off`. Ensure all detected frameworks are on current stable versions.

Technology-Specific Implementation

Apply remediation according to your web server and framework documentation.

POTENTIAL ATTACK PATHS

 POTENTIAL ATTACK PATHS

How findings chain into business impact

HIGH

Sensitive service ports publicly reachable (21) — direct attack surface for credential brute-force, vulnerability exploi

STEP 1

**External Exposure Signal
Identified**



STEP 2

Passive Reconnaissance
Incorporates Finding into
Target Dossier



STEP 3

Targeted Attack or Exploit
Developed



STEP 4

Vulnerability Leveraged
for Initial Access



STEP 5

Data Breach, Service
Disruption, or Lateral
Movement

MEDIUM**Content-Security-Policy header absent — application is unprotected against cross-site scripting (XSS) and content-inject****STEP 1****Missing Content-Security-Policy****STEP 2****Malicious Script Injected via XSS****STEP 3****User Browser Executes Attacker Code****STEP 4****Session Token / Credentials Exfiltrated****STEP 5****Account Compromised — Data Breach Risk**

MEDIUM

X-Frame-Options header absent — application may be embeddable in third-party frames, enabling clickjacking attacks again



TECHNICAL APPENDIX

A.1 — TLS CERTIFICATE DETAILS

ATTRIBUTE	VALUE
Reachable	Yes
Subject (CN)	cal.com
Issuer (CA)	WE1
Valid From	Feb 18 13:51:59 2026 GMT
Valid To	May 19 14:51:56 2026 GMT
Days Remaining	75
TLS Version	TLSv1.3
Cipher Suite	TLS_AES_256_GCM_SHA384
Certificate Expired	No

A.2 — SECURITY HEADER ANALYSIS

HEADER	PRESENT	VALUE
Strict-Transport-Security	Yes	max-age=31536000
Content-Security-Policy	No	—
X-Frame-Options	No	—
X-Content-Type-Options	Yes	nosniff
Referrer-Policy	No	—
Permissions-Policy	No	—
Cross-Origin-Opener-Policy	No	—
Cross-Origin-Resource-Policy	No	—

A.3 — OPEN PORT ENUMERATION

PORT	SERVICE	EXPOSURE CLASSIFICATION
21	FTP	High Exposure
80	HTTP	Standard Web
443	HTTPS	Standard Web
8080	HTTP (alt)	Standard Web
8443	HTTPS (alt)	Standard Web

A.4 — SUBDOMAIN ENUMERATION

1 host(s) resolved

cal.com

A.5 — DNS RECONNAISSANCE

A IPV4 ADDRESS RECORDS

104.18.0.62

104.18.1.62

MX MAIL EXCHANGE RECORDS

aspmx.l.google.com

alt3.aspmx.l.google.com

alt4.aspmx.l.google.com

alt1.aspmx.l.google.com

alt2.aspmx.l.google.com

TXT TEXT RECORDS

#	RECORD VALUE
1	MS=ms14963960
2	MS=ms52513678
3	MS=ms56097149
4	MS=ms98316148
5	apple-domain-verification=BWqXqkqcByIoJVFD
6	asv=4a2ed4b7d84c58fa042be983b359aea7
7	google-site-verification=ERZRBFAZod6YY2WsYOsXCN2QTXsLakqPluhPAWZORY
8	hubspot-developer-verification=MTUwNGIzOWYtYmYwMS00Y2IyLTg5YmEtNzEyZTU3NjczMGVj
9	openai-domain-verification=dv-2vLkO8g4fGLTXFv0086S4VGh
10	v=spf1 include:_spf.google.com include:sendgrid.net -all

SPF RECORD

v=spf1 include:_spf.google.com include:sendgrid.net -all

DMARC RECORD

Not found — without DMARC, phishing emails spoofing this domain may not be rejected.

A.6 — CERTIFICATE TRANSPARENCY (CRT.SH)

1 host(s) via CT logs

The following subdomains were discovered passively via certificate transparency log queries (crt.sh). CT logs record all issued certificates, revealing historical and current subdomain infrastructure.

cal.com

DISCLAIMER & LIMITATIONS

This report was generated by SentinelX v1.2.0 using exclusively passive, non-intrusive reconnaissance techniques. All data was collected from publicly observable sources including certificate transparency logs, public DNS records, HTTP response headers, and TCP port availability. No exploitation, credential testing, or authenticated access was performed. Findings represent risk indicators observable from the public internet and do not constitute a complete security assessment. A full penetration test by qualified security professionals is recommended to validate and prioritise these findings.

SentinelX External Exposure Intelligence Engine — Confidential Report — 2026-03-04 16:46 UTC